

Progetto finale

DATA: 20/02/2026

OGGETTO: Molteplici esercizi

REDATTORE: Argento Luca

Risposte Esercizio 1: Power Shell

Prompt dei comandi VS Power Shell

- **Quali sono gli output del comando dir?** Sia nel Prompt dei Comandi che in PowerShell, `dir` ti restituisce l'elenco dei file e delle sottodirectory presenti nella cartella in cui ti trovi.
- **Quali sono i risultati di comandi come ping, cd, e ipconfig?** I risultati sono esattamente gli stessi in entrambe le finestre.

Esplorare i cmdlet

- **Qual è il comando PowerShell per dir?** Scavando a fondo con `Get-Alias dir`, si scopre che `dir` è solo un travestimento. Il vero cmdlet di PowerShell, quello che fa il lavoro sporco, si chiama `Get-ChildItem`.

Netstat

- **Qual è il gateway IPv4?** 192.168.1.1.
- **Quali informazioni puoi ottenere dalla scheda Dettagli e dalla finestra Proprietà per il PID selezionato?** Da questa scheda estraiamo i dati di base che ci dicono dove si trova e quando è nato:
Nome e Tipo: Si chiama `ntoskrnl` ed è un file eseguibile, Applicazione (.exe).
Descrizione: È etichettato come NT Kernel & System.
Percorso: Risiede in `C:\Windows\system32`.
Cronologia Temporale: È stato creato e modificato originariamente venerdì 20 ottobre 2023, alle 11:33 circa.

Nome	PID	Stato	Nome utente	CPU	Memoria (w...)	Architett...	Descrizione
Interrupt sistema	-	In esecuzione	SYSTEM	00	0 K		Chiamate di pr...
Processo di inattività ...	0	In esecuzione	SYSTEM	94	8 K		Percentuale di t...
System	4	In esecuzione	SYSTEM	01	24 K		NT Kernel & Sy...
Registry	156	In esecuzione	SYSTEM	00	5.976 K x64		NT Kernel & Sy...
smss.exe	484	In esecuzione	SYSTEM	00	304 K x64		Gestione sessio...
svchost.exe	528	In esecuzione	SYSTEM	00	2.280 K x64		Processo host ...
csrss.exe	748	In esecuzione	SYSTEM	00	1.416 K x64		Processo runti...
svchost.exe	848	In esecuzione	SYSTEM	00	10.492 K x64		Processo host ...
wininit.exe	856	In esecuzione	SYSTEM	00	1.032 K x64		Applicazione di...
csrss.exe	864	In esecuzione	SYSTEM	00	2.420 K x64		Processo runti...
services.exe							App Servizi e C...
teaser.exe							Local Security A...

Svuotare il cestino

- **Cosa è successo ai file nel Cestino?** Inviando il comando `clear-recyclebin` e confermando con `y`, i file sono stati cancellati permanentemente dal disco.

Domanda di Riflessione

Comandi per semplificare i compiti di un analista di sicurezza: Visto che PowerShell serve per l'automazione delle attività, esistono numerosi comandi utili ai fini della sicurezza informatica, di seguito alcuni trovati facendo ricerca:

Quando si trova un file sospetto o un processo che consuma troppa CPU è meglio capire subito con chi si ha a che fare.

- `Get-FileHash -Algorithm SHA256 <percorso_file>`: Calcola istantaneamente l'impronta digitale (Hash) di un file. È essenziale per prendere questo valore e cercarlo su database di intelligence come VirusTotal per confermare se è un malware conosciuto.
- `Get-Process | Sort-Object CPU -Descending | Select-Object -First 5`: Trova i 5 processi che stanno consumando più risorse. I cryptominer, ad esempio, si nascondono proprio così.

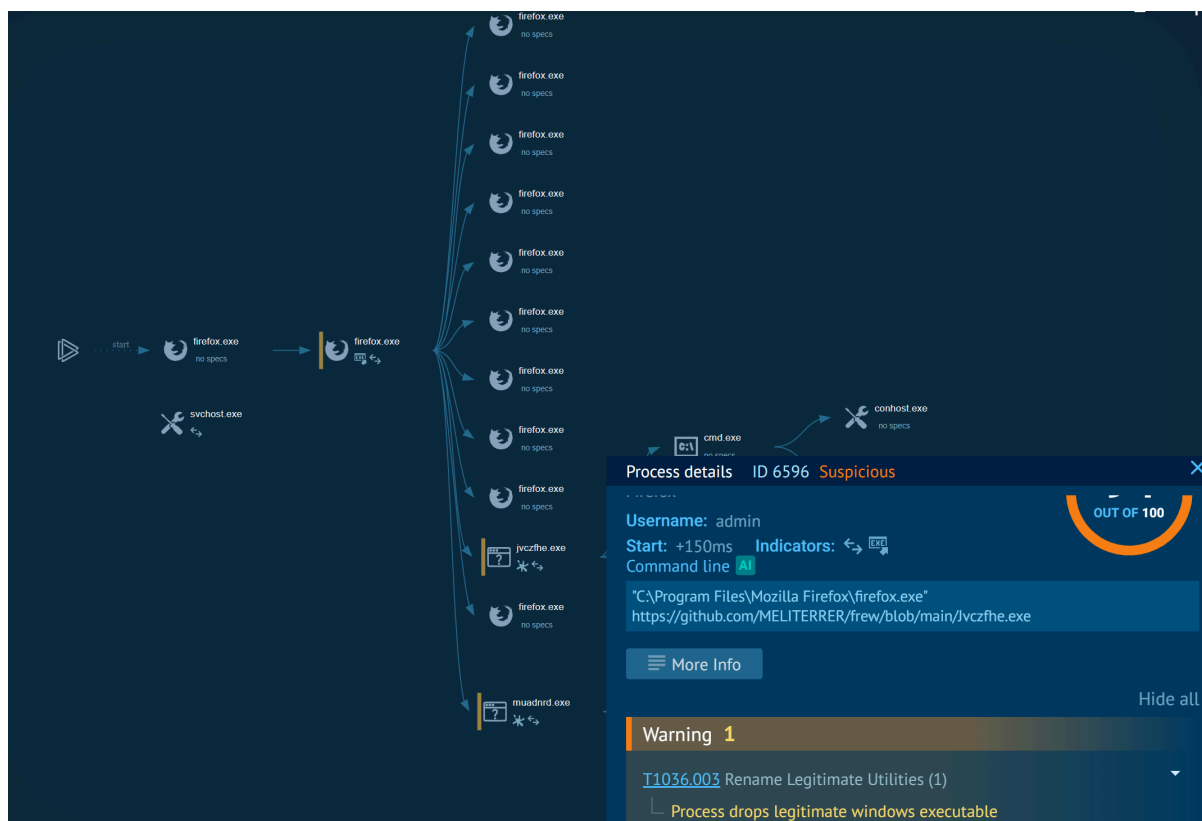
Gli attaccanti vogliono che il loro codice parta in automatico al riavvio del PC, quindi:

- `Get-CimInstance Win32_StartupCommand`: Elenca spietatamente tutti i programmi configurati per avviarsi in automatico con Windows. È il primo posto dove guardare per scovare malware persistenti.
- `Get-LocalGroupMember -Group "Administrators"`: Un comando velocissimo per verificare chi ha i privilegi massimi sul sistema. Se si vede un utente sconosciuto (magari creato di nascosto da un hacker), lo si scopre subito.

Report Esercizio 2: Analisi Malware

1. L'Inizio dell'Infezione

L'attacco non inizia con un virus magico che appare dal nulla, ma con un programma di uso quotidiano: il browser. Dall'albero dei processi vediamo chiaramente che tutto parte da **Firefox.exe**. Questo significa che l'utente ha usato il browser per visitare un link malevolo (in questo caso, un link ospitato su GitHub) e ha scaricato qualcosa che non doveva scaricare.



2. La Catena degli Eventi (Cosa fa il malware)

Una volta che Firefox ha fatto il lavoro sporco, scarica ed esegue due file con nomi palesemente generati a caso e sospetti: **Jvczfhe.exe** e **Muadnrd.exe**. Da qui, il malware inizia la sua operazione di mimetizzazione in tre mosse:

- **Mossa 1: Timeout.exe.** Entrambi i file maligni aprono una finestra di comando nascosta (`Cmd.exe`) e lanciano un programma chiamato `Timeout.exe`. Questo comando serve semplicemente a far "mettere in pausa" il sistema per un tot di secondi. Lo fanno per una ragione precisa: ingannare gli antivirus e i sistemi di analisi automatici, sperando che questi smettano di controllarli prima che il malware si svegli e inizi a fare danni.
- **Mossa 2: Abuso di programmi legittimi (Installutil.exe).** Il processo `Jvczfhe.exe` avvia `Installutil.exe`. Questo è un programma ufficiale di Windows che serve per installare servizi di sistema. Il malware lo sta

usando come "burattino" per eseguire le sue istruzioni facendole passare per operazioni di routine di Windows.

- **Mossa 3: Il travestimento finale (Werfault.exe).** Alla fine, entrambi i processi maligni fanno partire `Werfault.exe`. Questo è il programma legittimo di Windows che gestisce le "Segnalazioni di errore" (quello che compare quando un programma va in crash). Il malware non è andato in crash: ha semplicemente svuotato quel programma legittimo e ci si è nascosto dentro. Ora, se l'antivirus controlla, vede solo il gestore degli errori di Windows che sta lavorando, e lo lascia in pace.



3. Le Minacce Evidenziate

Basandoci su quello che vediamo, le minacce per il computer colpito sono evidenti:

- **Evasione Antivirus:** La minaccia più grande è che questo malware è progettato per essere invisibile. Usando le pause (Timeout) e nascondendosi dentro programmi di Windows (Installutil e Werfault), rende le difese standard quasi inutili.
- **Azione Silenziosa:** Poiché si nasconde nel processo di segnalazione errori, il malware può rimanere attivo in background per giorni o settimane. In questo tempo può rubare file, leggere le password salvate nel browser o

registrare i tasti premuti dalla vittima, tutto senza che l'utente si accorga di nulla.

Risposte Esercizio Bonus 1: Esplorazione di Nmap

- **Cos'è Nmap?** Nmap ("Network Mapper") è uno strumento open source per l'esplorazione della rete.
- **Per cosa viene usato nmap?** Viene progettato per scansionare rapidamente grandi reti. Nmap usa pacchetti IP raw per determinare quali host sono disponibili sulla rete, quali servizi offrono, quali sistemi operativi eseguono e il tipo di filtri di pacchetti/firewall in uso.
- **Cosa fa l'opzione -A?** Abilita il rilevamento del sistema operativo e della versione, la scansione degli script e il traceroute.
- **Cosa fa l'opzione -T4?** Serve per un'esecuzione più rapida.
- **Qual è il comando nmap usato nell'Esempio 1?** Il comando mostrato nel manuale è `# nmap -A -T4 scanme.nmap.org`.

Scansione delle Porte Aperte

Passo 1: Scansione del localhost

- **Quali porte e servizi sono aperti?** Ho due porte spalancate: la 21/tcp (servizio ftp) e la 22/tcp (servizio ssh).
- **Software che fornisce i servizi:**
Porta 21: vsftpd 2.0.8 or later (e lo script mi spiffera che è l'esatta versione vsFTPd 3.0.5).
Porta 22: OpenSSH 10.0 (protocol 2.0).

```

PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 2.0.8 or later
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_-rw-r--r--    1 0          0          0 Mar 26  2018 ftp_test
| ftp-syst:
|   STAT:
|   FTP server status:
|     Connected to 127.0.0.1
|     Logged in as ftp
|     TYPE: ASCII
|     No session bandwidth limit
|     Session timeout in seconds is 300
|     Control connection is plain text
|     Data connections will be plain text
|     At session startup, client count was 1
|     vsFTPD 3.0.5 - secure, fast, stable
|_End of status
22/tcp    open  ssh      OpenSSH 10.0 (protocol 2.0)
Service Info: Host: Welcome

Service detection performed. Please report any incorrect results at https://nmap
.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 11.93 seconds

```

Passo 2: Scansiona la tua rete

- **Indirizzo IP e subnet mask della VM:** Leggendo l'output di `ip address` l'IP della mia macchina è 192.168.1.82. La subnet mask è indicata dalla notazione CIDR /24 (che corrisponde a 255.255.255.0).
- **Rete della VM:** La mia VM fa parte della rete 192.168.1.0/24.
- **Quanti host sono attivi?** Il report finale di Nmap riporta che ci sono 3 hosts up.

Passo 3: Scansiona un server remoto (scanme.nmap.org)

- **Scopo del sito:** Si tratta di un bersaglio legittimo fornito dai creatori di Nmap per permettere agli utenti di testare e imparare senza finire in prigione per aver scansionato infrastrutture altrui senza permesso.
- **Porti e servizi aperti:** 22/tcp (ssh, OpenSSH 6.6.1p1), 80/tcp (http, Apache httpd 2.4.7), 9929/tcp (nping-echo), e la 31337/tcp (tcpwrapped).
- **Quali porte e servizi sono filtrati?** A differenza dell'esempio nel manuale del PDF, nel mio scan reale non c'è traccia di porte filtrate. L'output dice chiaramente: *Not shown: 996 closed tcp ports (conn-refused).*

```
[analyst@secOps ~]$ nmap -A -T4 scanme.nmap.org
Starting Nmap 7.97 ( https://nmap.org ) at 2026-02-20 07:09 -0500
Nmap scan report for scanme.nmap.org (45.33.32.156)
Host is up (0.18s latency).
Other addresses for scanme.nmap.org (not scanned): 2600:3c01::f03c:91ff:fe18:bb2f
Not shown: 996 closed tcp ports (conn-refused)
PORT      STATE SERVICE      VERSION
22/tcp    open  ssh          OpenSSH 6.6.1p1 Ubuntu 2ubuntu2.13 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|   2048 20:3d:2d:44:62:2a:b0:5a:9d:b5:b3:05:14:c2:a6:b2 (RSA)
|   256 96:02:bb:5e:57:54:1c:4e:45:2f:56:4c:4a:24:b2:57 (ECDSA)
|_  256 33:fa:91:0f:e0:e1:7b:1f:6d:05:a2:b0:f1:54:41:56 (ED25519)
80/tcp    open  http         Apache httpd 2.4.7 ((Ubuntu))
|_ http-title: Go ahead and ScanMe!
|_ http-server-header: Apache/2.4.7 (Ubuntu)
|_ http-favicon: Nmap Project
9929/tcp  open  nping-echo   Nping echo
31337/tcp open  tcpwrapped
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

- **Indirizzo IP del server:** 45.33.32.156.
- **Sistema operativo:** Linux (Ubuntu), ricavato sia dai banner di SSH/Apache, sia dal Service Info (OS: Linux; CPE: cpe:/o:linux:linux_kernel).

Domanda di Riflessione Finale

Come può Nmap aiutare con la sicurezza o essere usato come strumento

nefasto? La scansione delle porte fa solitamente parte di un attacco di ricognizione. Nmap è una potente utility di rete usata per la scoperta della rete e l'audit di sicurezza. Un amministratore se ne serve per fare l'inventario, controllare gli uptime e assicurarsi che firewall e servizi siano configurati bene. Un attaccante, d'altro canto, usa Nmap per la "ricognizione": capire quali porte sono aperte, quali sistemi operativi (e relative versioni vulnerabili) girano dietro agli IP, usando pacchetti IP raw per mappare la rete e preparare il colpo letale. Nmap non è né buono né cattivo, è semplicemente visione e a seconda dello scopo può aiutare la sicurezza come può essere usato come strumento nefasto.

Risposte Esercizio Bonus 2: Attacco SQL Injection

- **Quali sono i due indirizzi IP coinvolti in questo attacco di SQL injection in base alle informazioni visualizzate?** I due attori di questa danza sono

l'indirizzo IP dell'aggressore (10.0.2.4), che invia le richieste malevole, e l'indirizzo IP della vittima (10.0.2.15), che ospita l'applicazione web.

- **Qual è la versione?** La versione del database estorta è 5.7.12-0ubuntu1.1. L'aggressore l'ha ottenuta iniettando il comando `version()`.
- **Quale utente ha l'hash della password di `8d3533d75ae2c3966d7e0d4fcc69216b`?** Quell'hash appartiene all'utente 1337.
- **Qual è la password in chiaro?** Utilizzando un sito come CrackStation ricaviamo che quel valore, un vecchissimo e banale hash MD5, decifrato è `charley`.